Incident Response Lab Report

Name: INNOCENT UTU
Date: 15/5/2026

Preparation

Objective

The objective of the preparation phase was to evaluate SecureHealth's readiness to respond to cybersecurity incidents, particularly ransomware attacks targeting healthcare systems and patient data.

Roles, Responsibilities, and Tools

Role	Responsibility	Current Evaluation
Incident Response Team	Coordinate incident handling and recovery	Well-defined but understaffed
IT Security Team	Monitor systems and analyze alerts	Effective monitoring tools available
Compliance Team	Ensure HIPAA compliance and reporting	Strong compliance oversight
System Administrators	Manage system restoration and patching	Adequate but limited automation
Executive Leadership	Approve response decisions and communication	Clear escalation procedures

Security Tools in Place

- CrowdStrike Endpoint Detection and Response (EDR)
- Recorded Future Threat Intelligence Platform
- Veeam Backup and Recovery Solutions
- SIEM monitoring systems

- Email security gateways
- Multi-Factor Authentication (MFA)

Strengths

- Strong endpoint monitoring capabilities.
- Reliable backup and recovery systems.
- Threat intelligence integration supports proactive defense.
- Compliance policies aligned with HIPAA requirements.

Weaknesses and Gaps

- Limited phishing awareness training among employees.
- Incomplete incident response automation.
- Insufficient threat hunting capabilities.
- Lack of regular tabletop incident response exercises.
- Limited third-party vendor security monitoring.

Recommendations

- Conduct quarterly incident response simulations.
- Expand employee cybersecurity awareness training.
- Increase automation within SIEM and EDR workflows.
- Implement stronger vendor risk management controls.
- Improve staffing for incident response and threat hunting teams.

Detection and Identification

Indicators of Compromise (IoCs)

IoC	Description
Suspicious email attachments	Phishing emails containing malicious files
Unusual PowerShell activity	Encoded or unauthorized PowerShell commands
Failed login attempts	Multiple unsuccessful authentication attempts

Unauthorized remote access sessions	Remote logins outside normal business hours
Encrypted files and ransom notes	Indicators of ransomware deployment
Disabled endpoint protection services	Evidence of defense evasion

---

Log and Alert Analysis

Security logs revealed multiple phishing emails sent to employees with malicious attachments disguised as healthcare-related documents. Email gateway logs identified suspicious sender domains and malicious file hashes associated with known ransomware campaigns.

Endpoint detection alerts showed abnormal PowerShell execution, unauthorized remote desktop sessions, and rapid file encryption activity across multiple endpoints. SIEM correlation analysis confirmed lateral movement between systems and attempts to disable security services before ransomware deployment.

Authentication logs also showed repeated failed login attempts followed by successful logins from unusual geographic locations, indicating possible credential compromise.

Incident Scope and Severity

Affected Systems

- Electronic Medical Record (EMR) servers
- Employee workstations
- Telehealth systems
- Shared network drives

Affected Data

- Patient healthcare records
- Internal operational documents
- User credentials

Severity Assessment

The incident is classified as a **P1 Critical Incident** due to:

- Operational disruption affecting patient care.
- Risk of sensitive patient data exposure.
- Multiple systems impacted by ransomware.
- Potential HIPAA compliance violations.

Containment

Short-Term Actions

Action	Purpose
Isolate infected systems	Prevent ransomware spread
Disable compromised accounts	Stop unauthorized access
Block malicious IP addresses and domains	Prevent attacker communication
Disconnect affected servers from the network	Reduce lateral movement
Preserve forensic evidence	Support investigation and legal requirements

Immediate Response Actions

- Disable remote access for affected accounts.
- Quarantine malicious email attachments.
- Notify internal response teams and leadership.

Long-Term Strategies

Strategy	Purpose
Network segmentation	Limit future lateral movement
Enhanced phishing protection	Reduce successful phishing attacks
Patch management improvements	Close known vulnerabilities

Expanded EDR deployment	Improve threat detection
Zero Trust security implementation	Strengthen access controls

Additional Recommendations

- Regular vulnerability assessments.
- Stronger access monitoring policies.
- Third-party vendor security reviews.

Eradication

Root Cause Analysis

The incident began with phishing emails containing malicious attachments sent to employees. One or more users opened the attachments, allowing malware execution and credential compromise. Attackers then used stolen credentials and remote access tools to move laterally across SecureHealth's environment before deploying ransomware.

The attack succeeded because of:

- Insufficient phishing awareness training.
- Weak credential protection measures.
- Limited segmentation between systems.
- Incomplete monitoring of remote access activity.

Eradication Steps

Step	Purpose
Remove malicious files and ransomware payloads	Eliminate malware presence
Reset compromised user credentials	Prevent unauthorized access
Reimage infected systems	Ensure systems are clean

Disable malicious scheduled tasks and scripts	Remove persistence mechanisms
Apply security patches	Address exploited vulnerabilities

Additional Actions

- Conduct malware scans across all systems.
- Verify endpoint security tools are fully operational.
- Remove unauthorized remote access configurations.

Recovery

Restoration Process

Affected systems will be restored using secure offline backups maintained through Veeam backup solutions.

Recovery Steps

1. Restore critical EMR servers first.
2. Restore telehealth and operational systems.
3. Reconnect systems after validation.
4. Re-enable remote services securely.

Verification Steps

Verification Activity	Purpose
Full antivirus and EDR scans	Confirm malware removal
User authentication testing	Ensure account security
System functionality testing	Verify operational readiness
Log review and monitoring	Detect residual threats

Post-Recovery Monitoring

- Monitor SIEM alerts continuously.
- Track unusual login activity.
- Conduct ongoing endpoint monitoring.
- Review network traffic for suspicious behavior.
- Perform additional threat hunting activities.

Post-Incident Review

What Worked Well

- Rapid isolation of infected systems reduced spread.
- Backup systems enabled restoration of critical services.
- SIEM and EDR tools provided valuable visibility.
- Internal communication procedures were effective.

Areas for Improvement

- Delayed identification of phishing activity.
- Limited employee awareness regarding malicious attachments.
- Incomplete automation slowed response efforts.
- Vendor access monitoring was insufficient.

Updated IR Plan Recommendations

Recommendation	Benefit
Increase phishing simulations	Improve employee awareness
Conduct regular IR tabletop exercises	Improve team coordination
Expand security automation	Reduce response time
Strengthen vendor risk management	Reduce third-party exposure

Improve logging and monitoring coverage	Enhance detection capabilities

---

Continuous Improvement

Process Refinements

- Conduct quarterly incident response drills.
- Update incident response playbooks regularly.
- Improve coordination between departments.
- Enhance threat intelligence integration workflows.

New Security Measures

Security Measure	Purpose
Zero Trust architecture	Improve access security
Advanced email filtering	Prevent phishing attacks
Network segmentation	Limit ransomware spread
Behavioral analytics tools	Detect abnormal activity
Multi-factor authentication	Protect user accounts

Training Recommendations

- Phishing awareness training for all employees.
- Advanced ransomware response training for security teams.
- Threat hunting and forensic investigation workshops.
- HIPAA-focused cybersecurity compliance training.

These improvements will strengthen SecureHealth’s resilience against future ransomware attacks and improve overall incident response readiness.

Conclusion

The incident response process successfully identified, contained, eradicated, and recovered from a ransomware attack targeting SecureHealth's healthcare infrastructure. The investigation revealed that phishing, credential compromise, and lateral movement techniques were used to deploy ransomware and disrupt critical healthcare services.

Key recommendations include improving phishing awareness training, expanding threat detection capabilities, implementing stronger access controls, and increasing incident response automation. By addressing these gaps, SecureHealth can significantly improve its security posture and reduce the likelihood and impact of future cyberattacks.